

Launch Readiness: Quick Desktop AI Control Tower

Executive Summary

Amazon Quick Desktop AI Control Tower is a cross-vendor AI governance capability embedded within the Quick Desktop agent, enabling enterprises to discover shadow AI, enforce governance policies, attribute costs, and measure adoption maturity from the desktop. The product targets mid-market IT operations leaders who currently spend weeks manually answering executive AI questions. Engineering delivery spans four 2-week sprints (8 weeks), with internal dogfood in Week 9, beta in Weeks 10-11, and GA in Week 12.

1. Engineering Spec

System Components

Component	Design Spec Section	Description	New/Modified
Discovery Engine	Phase 1: Primary User Task; Nav Map #2 (AI Inventory)	Hybrid detection combining desktop signals (process names, browser domains, integration layer activity) with vendor admin API polling. Maintains the organizational AI tool registry.	New
Command Center Aggregator	Nav Map #1 (Command Center); 3F Data Viz Matrix	Computes 5 hero KPIs (tools discovered, spend, governed %, active risks, maturity level) from Discovery Engine + Policy Engine + Cost Engine data. Pre-aggregated on a 5-minute refresh cycle.	New
Governance Policy Engine	Nav Map #3 (Governance); Phase 2: Inline action model	Rule engine supporting approved/blocked tool lists and basic data sensitivity pattern matching (regex-based PII detection). Evaluates rules against desktop activity signals and triggers nudge notifications.	New
Security Risk Detector	Nav Map #4 (Security & Risk)	Pattern-matching layer that monitors for sensitive data exposure to unapproved AI tools. Integrates with Bedrock Guardrails status API. Produces risk alerts with severity scoring.	New
Cost Attribution Engine	Nav Map #5 (Cost Attribution); 3F (stacked bar/horizontal bar)	Aggregates billing data from vendor admin APIs (AWS Cost Explorer, M365 Admin, OpenAI Org API). Maps spend to teams via SSO/IdP user-to-team resolution.	New

Component	Design Spec Section	Description	New/Modified
Maturity Scoring Service	Nav Map #6 (Adoption & Maturity)	Computes 5-level maturity score per team from Discovery + Policy + Cost signals. No new data collection — derived from existing engines.	New
Admin Console Backend	Nav Map #7 (Admin Console), #13 (Audit Log)	CRUD APIs for policy management, integration configuration, notification preferences, team setup. Writes all governance actions to the activity audit log.	New
Frontend Shell	Phase 2: App Layout; 3H Responsive Specs	Cloudscape-based SPA with sidebar navigation (7 primary + 6 sub-nav), split panel, property filter, modals. Targets L breakpoint (1200-1599px).	New
URL State Manager	3J Deep-Link Strategy	Serializes/deserializes UI state (filters, selected tool, active tab, time range) to URL query parameters for deep-linking.	New
User Preferences API	3K FTUX; Phase 2: Saved Views	Stores saved filter views, onboarding state, collection preferences, notification settings per user. Extends Quick Desktop's existing preferences infrastructure.	Modified

API Contracts (Key Endpoints)

Endpoint	Method	Request	Response	Auth
/api/v1/discovery/tools`	GET	?team=&vendor=&status=&page=&size=`	{ tools: Tool[], total: int, page: int }	IAM + QD session
/api/v1/discovery/tools/{id}`	GET	—	{ tool: ToolDetail }` (users, cost, compliance, activity)	IAM + QD session
/api/v1/governance/policies`	GET/POST/PUT/DELETE	Policy CRUD body	{ policy: Policy }	IAM + Admin role
/api/v1/governance/evaluate`	POST	{ toolId, userId, action, dataContext }	{ decision: allow/nudge/block, nudgeContent }	Internal service
/api/v1/cost/attribution`	GET	?vendor=&team=&start=&end=`	{ byVendor: [], byTeam: [], total: Money }	IAM + QD session
/api/v1/maturity/scores`	GET	?team=&level=`	{ orgScore: int, teams: TeamScore[] }	IAM + QD session
/api/v1/audit/events`	GET	?actor=&action=&target=&start=&end=`	{ events: AuditEvent[], total: int }	IAM + Admin role

Endpoint	Method	Request	Response	Auth
/api/v1/admin/integrations`	GET/POST/DELETE	Integration config body	{ integration: Integration }	IAM + Admin role

Error responses follow standard Quick Desktop API patterns: { error: { code, message, retryable } }.

Data Model Changes

Table	Purpose	Key Columns	Indexes
`ai_tools`	Discovered AI tool registry	`tool_id` (PK), `name`, `vendor`, `category`, `discovery_source`, `first_seen`, `last_seen`, `status`	`vendor`, `status`, `first_seen`
`ai_tool_usage`	Per-user per-tool activity signals	`usage_id` (PK), `tool_id` (FK), `team_id`, `user_hash`, `activity_date`, `interaction_count`	`tool_id + activity_date`, `team_id`
`governance_policies`	Policy rules	`policy_id` (PK), `name`, `scope`, `tool_ids`, `enforcement_level`, `conditions_json`, `created_by`, `created_at`	`enforcement_level`, `scope`
`governance_events`	Audit log of all governance actions	`event_id` (PK), `actor`, `action`, `target_tool_id`, `target_policy_id`, `timestamp`, `details_json`	`timestamp`, `actor`, `action`
`cost_records`	Vendor cost data snapshots	`record_id` (PK), `vendor`, `team_id`, `period`, `amount`, `currency`, `source`	`vendor + period`, `team_id + period`
`maturity_scores`	Computed maturity snapshots	`score_id` (PK), `team_id`, `level`, `computed_at`, `factors_json`	`team_id + computed_at`
`user_preferences`	Saved views, onboarding state	`pref_id` (PK), `user_id`, `key`, `value_json`	`user_id + key`

Performance Requirements

- Command Center page load: < 2s (p99), hero KPIs pre-aggregated
- AI Inventory table render (18-50 tools): < 1s (p99)
- Split panel open: < 200ms (p99)
- Policy evaluation (governance nudge decision): < 500ms (p99) — Open Question #4 from PRD
- Discovery Engine scan cycle: < 5 minutes per endpoint
- Cost attribution refresh: daily batch, < 30 minutes per organization
- Availability SLA: 99.9% for dashboard; 99.95% for governance evaluation path

2. Acceptance Criteria

[AC-1] Traces to: JTBD-1

GIVEN Lisa opens AI Control Tower Command Center

WHEN the page finishes loading

THEN the hero KPI bar displays 5 metrics (tools discovered, monthly spend, governed %, active risks, maturity level) with data no older than 5 minutes

[AC-2] Traces to: JTBD-1

GIVEN the Discovery Engine has completed a scan cycle

WHEN Lisa views the AI Inventory page

THEN all discovered tools appear in a sortable, filterable, paginated table showing name, vendor, users, cost, status, and risk level

[AC-3] Traces to: JTBD-2 / DD-4 (inline policy action)

GIVEN Lisa clicks a tool row in AI Inventory

WHEN the split panel opens

THEN it displays 4 tabs (Overview, Users, Cost, Compliance) with tool-specific data, and an "Apply Policy" button is visible

[AC-4] Traces to: JTBD-2

GIVEN Lisa clicks "Apply Policy" for an unapproved tool

WHEN she selects "Approve with conditions" and configures a data sensitivity nudge

THEN the policy is saved, the tool status updates to "Approved," and the audit log records the action with her identity and timestamp

[AC-5] Traces to: JTBD-2

GIVEN a user pastes text matching sensitive data patterns into an unapproved AI tool

WHEN the Governance Policy Engine evaluates the action

THEN a contextual nudge appears within 500ms suggesting a compliant alternative, and the user can accept, dismiss, or snooze

[AC-6] Traces to: JTBD-3

GIVEN vendor integrations are connected (AWS, M365, OpenAI)

WHEN Lisa opens Cost Attribution

THEN costs are displayed by vendor (stacked bar) and by team (horizontal bar) with drill-down to per-tool detail

[AC-7] Traces to: JTBD-3

GIVEN 30 days of data exist

WHEN Lisa views Adoption & Maturity

THEN each team shows a maturity level (1-5) with specific criteria for advancing to the next level

[AC-8] Traces to: JTBD-5

GIVEN governance actions have been taken (policy changes, approvals, blocks)

WHEN Lisa or the CISO opens the Activity Audit Log

THEN all actions appear in a filterable log with timestamp, actor, action type, and target — suitable for compliance audit evidence

[AC-9] Traces to: DD-7 (deep-link URL state)

GIVEN Lisa has applied filters and selected a tool in AI Inventory

WHEN she copies the current URL and shares it via Slack

THEN opening that URL restores the exact filter state, tab selection, and split panel tool

[AC-10] Traces to: JTBD-1 / DD-3 (opinionated KPI hub)

GIVEN the Discovery Engine detects a new shadow AI tool

WHEN Lisa next visits the Command Center

THEN a dismissible alert appears in the shadow AI alert zone showing the tool name, team, and recommended action

[AC-11] Traces to: JTBD-4

GIVEN multiple AI tools exist with overlapping capabilities

WHEN Lisa views the AI Inventory filtered by a capability category

THEN she can compare tool metrics (users, cost, compliance, risk) side-by-side to inform procurement decisions

[AC-12] Traces to: DD-1 (sidebar navigation)

GIVEN Lisa is on any page

WHEN she uses sidebar navigation

THEN she can reach all 8 Eng v1 pages (Command Center, AI Inventory, Governance, Security, Cost Attribution, Adoption, Admin Console, Audit Log) within 1 click

[AC-13] Traces to: JTBD-2

GIVEN an admin configures a "Block" policy for a tool

WHEN a user attempts to interact with the blocked tool through Quick Desktop

THEN Quick Desktop surfaces a block notification with the reason and a link to approved alternatives

3. Sprint Breakdown

Sprint	Dates	Scope	Deliverables	Dependencies	Exit Criteria
S1 (Foundation)	Weeks 1-2	Data model, API stubs, feature flags, Discovery Engine skeleton, frontend shell	Schema deployed to dev, all API endpoints returning mock data, Cloudscape shell with sidebar nav, feature flag for AI Control Tower	None	Schema migration passes review, all endpoints return 200, feature flag toggleable in dev
S2 (Core Engines)	Weeks 3-4	Discovery Engine (desktop + top 3 vendor integrations), Governance Policy Engine (rules + nudges), Cost Attribution Engine (3 vendor APIs)	Discovery Engine detects desktop AI tools, policy CRUD operational, cost data flowing from at least 1 vendor	S1 complete; vendor API credentials (M365, OpenAI)	Unit tests 90%+ coverage, Discovery Engine detects 5+ known AI tools in test environment, policy evaluation < 500ms

Sprint	Dates	Scope	Deliverables	Dependencies	Exit Criteria
S3 (UI + Integration)	Weeks 5-6	All 8 Eng v1 pages built with real data, split panel, property filter, modals, dark mode, URL state management, maturity scoring	Full UI end-to-end with live data, deep-linking functional, maturity scores computed	S2 complete	E2E tests pass all AC-1 through AC-13, design review sign-off, accessibility audit (WCAG AA)
S4 (Hardening)	Weeks 7-8	Performance tuning, monitoring dashboards, security review, documentation, load testing, onboarding flow	Load test passing, runbooks written, CloudWatch dashboards deployed, onboarding tour functional	S3 complete	Load test: 1000 concurrent users < 2s p99, security review complete, all monitoring alarms configured

4. Dependency RACI

Dependency	Responsible	Accountable	Consulted	Informed	Timeline
QD Knowledge Graph API access	QD Core Engineering	QD Core EM	AI Control Tower PM	QD Leadership	Week 1 (S1)
M365 Admin Center API partnership	Partnerships Team	Partnerships Lead	PM, Legal	Engineering	Week 3 (S2)
OpenAI Organization API access	Partnerships Team	Partnerships Lead	PM, Engineering	Legal	Week 3 (S2)
AWS Bedrock/Cost Explorer APIs	AI Control Tower Engineering	AI CT EM	Solutions Architecture	PM	Week 2 (S1)
SSO/IdP user-to-team mapping	QD Enterprise Team	QD Enterprise EM	AI CT Engineering	PM	Week 2 (S1)
Legal/Privacy framework review	Legal Team	Legal Counsel	PM, Engineering, Privacy	QD Leadership, Marketing	Week 1 start, Week 8 completion
UX Research interviews (8-10 customers)	UXR Team	UXR Lead	PM, Design	Engineering	Week 4 (S2)
QD Admin Console infrastructure	QD Enterprise Team	QD Enterprise EM	AI CT Engineering	PM	Week 2 (S1)
Security review (IAM, encryption)	Security Engineering	Security Lead	AI CT Engineering	Legal, PM	Week 7 (S4)

5. Phased Rollout Plan

Phase	Scope	Duration	Success Gate	Rollback Trigger
0 (Internal dogfood)	Feature flag on, Amazon internal teams only (50-100 users)	1 week	No P0/P1 bugs, Command Center p99 < 2s, Discovery Engine finds 3+ shadow AI tools, nudge latency < 500ms	Any P0 bug, p99 > 3s, data leak, or privacy concern raised
1 (Beta)	Opt-in for 10 pilot enterprise organizations, ~2,000 users	2 weeks	Error rate < 1%, no data-related incidents, discovery accuracy > 80% (precision), user override rate < 50%, CSAT > 3.5	Error rate > 2%, any security incident, override rate > 60%, CSAT < 3.0
2 (GA)	Available to all Quick Desktop Professional/Enterprise tiers, discovery teaser in Plus	Ongoing	North Star (% discovered & governed) > 30% within 3 months, 5+ shadow AI tools discovered per org in 30 days, cross-vendor cost visibility > 60%	North Star < 15% after 3 months, fewer than 2 shadow AI tools per org, negative press/analyst coverage

6. Rollback Procedures

Phase 0 → Revert

Layer	Rollback Action	Estimated Time	Owner
Feature flag	Disable `ai-control-tower-enabled` flag via QD Feature Service	< 1 min	On-call engineer
Data	No rollback needed — Phase 0 data stays in dev partition. Purge with `DELETE FROM ai_tools WHERE env='internal'` if needed	< 5 min	DB owner
Service	Redeploy previous Quick Desktop version without CT endpoints	< 15 min	Service owner

Phase 1 → Phase 0

Layer	Rollback Action	Estimated Time	Owner
Feature flag	Restrict flag to internal-only audiences	< 1 min	On-call engineer
Data	Beta org data preserved but hidden. No schema rollback.	Instant	DB owner
Service	No redeploy needed — flag controls visibility	< 1 min	On-call engineer

Phase 2 → Phase 1

Layer	Rollback Action	Estimated Time	Owner
Feature flag	Restrict to beta org allowlist	< 1 min	On-call engineer
Data	GA org data preserved. Cost data paused via integration disconnect.	< 5 min	Service owner
Service	No redeploy needed for soft rollback. Hard rollback: redeploy beta build.	< 15 min	Service owner

Pre-rollback validation: Confirm current error rates, check for in-flight policy evaluations. **Post-rollback smoke tests:** Verify Command Center loads for remaining audience, confirm governance nudges stop for rolled-back users.

Communication: Notify affected organizations via email template (pre-drafted in launch kit), post in internal Slack #ai-control-tower-oncall.

7. Data Migration Plan

Schema changes: 7 new tables (see Engineering Spec §Data Model). No modification to existing Quick Desktop tables. All new tables use standard Quick Desktop partition scheme (org_id-based sharding).

Migration strategy: Online migration via schema-only deployment in S1. No data backfill needed — all tables start empty and populate from Discovery Engine, governance actions, and vendor API polling. Cost data backfill for historical periods is a v2 feature.

Backward compatibility: Old Quick Desktop code does not read new tables. New code does not modify existing tables. Zero coupling ensures safe rollback.

Zero-downtime approach: Schema deployed via blue-green deployment. New tables created in shadow, feature flag gates all reads/writes to new tables. Flag off = zero traffic to new schema.

Rollback: Drop new tables. No impact on existing Quick Desktop functionality. `DROP TABLE IF EXISTS ai_tools, ai_tool_usage, governance_policies, governance_events, cost_records, maturity_scores, user_preferences CASCADE;`

Data validation: Post-migration integrity check: verify FK constraints, run `COUNT(*)` on all tables, validate index creation via `EXPLAIN` on key queries.

8. Monitoring & Alerting Plan

Component	Dashboard	Key Metrics	Alarm	Threshold	Runbook
Command Center API	CW: AI-CT-CommandCenter	Latency p50/p99, error rate, throughput	CT-CommandCenter-Latency-P99	p99 > 2s for 3 consecutive 1-min periods	`/runbooks/ai-ct/command-center.md`
Discovery Engine	CW: AI-CT-Discovery	Scan duration, tools found per cycle, error rate, queue depth	CT-Discovery-Errors	Error rate > 5% for 5 min	`/runbooks/ai-ct/discovery-engine.md`
Governance Evaluator	CW: AI-CT-Governance	Evaluation latency p99, nudge delivery rate, override rate	CT-Governance-Latency-P99	p99 > 500ms for 3 min (PRD Open Question #4)	`/runbooks/ai-ct/governance-eval.md`
Cost Attribution	CW: AI-CT-Cost	Refresh success rate, vendor API latency, stale data age	CT-Cost-Staleness Alarm	Data older than 48h	`/runbooks/ai-ct/cost-attribution.md`

Component	Dashboard	Key Metrics	Alarm	Threshold	Runbook
Frontend	CW: AI-CT-Frontend	Page load time, JS error rate, client-side crash rate	CT-Frontend-Errors	JS error rate > 1% for 10 min	`/runbooks/ai-ct/frontend.md`
Vendor API Integrations	CW: AI-CT-Integrations	Per-vendor API success rate, latency, auth failures	CT-Integration-[Vendor]-Failure	Any vendor auth failure or > 10% error rate for 5 min	`/runbooks/ai-ct/vendor-integrations.md`

Pre-launch baseline capture: Record 7-day baseline for QD core metrics (page load, API latency, error rate) before Phase 0 to detect regressions attributable to AI Control Tower code.

Canary alarms (Phase 0): Separate alarm namespace CT-Canary-* with tighter thresholds (50% of GA thresholds). Auto-page on-call if any canary alarm fires.

Composite alarms (Phase 1+): CT-Composite-ServiceHealth triggers if ANY of: error rate > 2% AND latency p99 > 3s AND availability < 99.5% — all within the same 5-minute window.

Log Insights queries: Pre-configured queries: "Top errors by exception class," "Slow governance evaluations > 500ms," "Discovery scan failures by vendor," "Policy evaluation outcomes by decision type."

9. Security Review Checklist

- **IAM policies follow least-privilege:** Discovery Engine reads QD knowledge graph signals (read-only). Admin API requires ai-ct:admin role. Cost API requires ai-ct:viewer or above. Governance evaluation is an internal service-to-service call with mTLS.
- **Cross-account trust boundaries documented:** Vendor API integrations (M365, OpenAI) use org-scoped OAuth tokens stored in AWS Secrets Manager. No cross-AWS-account trust needed — all within QD's existing AWS account.
- **Data encryption at rest and in transit:** All new tables encrypted with AES-256 (AWS RDS default). All API traffic over TLS 1.3. Vendor API calls over HTTPS.
- **PII handling and data classification:** Discovery signals are application-level metadata (tool names, domains, interaction counts) — NOT content. User identity stored as hashed user IDs in ai_tool_usage. Individual-level data requires explicit admin opt-in. PRD FAQ Q5 privacy safeguards enforced.
- **API authentication and authorization model reviewed:** All endpoints behind QD session auth + IAM role check. Admin endpoints require elevated role. No public endpoints.
- **Input validation and injection prevention:** Policy conditions_json validated against JSON schema. Property filter input sanitized against SQL injection. All user inputs parameterized.
- **Audit logging for sensitive operations:** All governance actions (policy CRUD, tool approve/block, configuration changes) written to governance_events table with actor, timestamp, and action detail. Immutable append-only log.
- **Dependency vulnerability scan clean:** Required as S4 exit criteria. Snyk/Dependabot scan on all new dependencies.

10. Tech Debt Register

ID	Shortcut	Location	Proper Solution	Priority	Sprint Target
TD-1	Simple text search instead of Cloudscape Property Filter tokens	Prototype: search input on AI Inventory	Implement full Cloudscape Property Filter with typed tokens (vendor, team, status, risk)	P2	S3
TD-2	CSS-based charts instead of Chart.js/D3	Prototype: Cost Attribution, Adoption pages	Replace with Cloudscape-wrapped Chart.js or D3 charts with proper axes, tooltips, legends	P2	S3
TD-3	No skeleton loading states	Prototype: all pages	Implement Cloudscape skeleton loading pattern on every data-dependent component	P2	S3
TD-4	No URL state management	Prototype: navigation	Implement URL serialization/deserialization for filters, tabs, selections per design spec 3J	P1	S3
TD-5	Simplified ARIA (missing search, complementary roles)	Prototype: App Layout	Full ARIA landmark coverage per design spec 3I, screen reader announcements via aria-live	P1	S3
TD-6	No `prefers-reduced-motion` respect	Prototype: animations	Add CSS media query to disable all transitions when user preference is set	P3	S4
TD-7	Mock data inline in HTML	Prototype: all pages	Replace with real API calls, implement data fetching layer with error/loading/empty states	P1	S2
TD-8	No Collection Preferences	Prototype: tables	Implement Cloudscape Collection Preferences for column visibility, density, page size	P2	S3
TD-9	No saved views	Prototype: AI Inventory	Implement saved filter views using User Preferences API	P2	S4

ID	Shortcut	Location	Proper Solution	Priority	Sprint Target
TD-10	No date range picker	Prototype: all time-sensitive views	Implement Cloudscape Date Range Picker with global time filter	P1	S3

11. Success Metrics

Metric	Type	Target	Instrumentation	Dashboard
% AI tools discovered & governed (North Star)	Gauge	70% within 6 months	`discovery_engine.tools.governed_ratio` emitted every scan cycle	CW: AI-CT-NorthStar
Time to complete AI inventory	Histogram	< 1 hour (automated)	Timer from first integration connect to first Command Center view	CW: AI-CT-Onboarding
Shadow AI tools detected per org	Counter	5+ in first 30 days	`discovery_engine.shadow_ai.count` per org per day	CW: AI-CT-Discovery
Cross-vendor cost visibility (% spend attributed)	Gauge	> 80% of AI spend	`cost_engine.attributed_spend_ratio` daily	CW: AI-CT-Cost
Governance nudge override rate (anti-metric)	Gauge	< 40%	`governance.nudge.override_rate` per 7-day window	CW: AI-CT-Governance
Time-to-value (first discovery insight)	Histogram	< 30 min	Timer from CT feature flag enable to first shadow AI alert	CW: AI-CT-Onboarding

12. Meeting Deck Outline

#	Topic	Duration	Source
1	Problem recap — Lisa's 2-week CEO investigation, 82% unknown agents	2 min	PRD §1 (Customer Problem)
2	Competitive context — ServiceNow AI Control Tower, why desktop-level governance is unique	2 min	Research v1, PRD §2 (Competitive Differentiation)
3	Solution overview — 6 capabilities, "cockpit not control tower" positioning	3 min	PRD §2 (Solution Proposal)
4	Design walkthrough — live prototype demo, 5-minute demo script	5 min	Design spec (Demo Script), prototype-v1.html
5	Engineering spec — components, APIs, data model, performance targets	5 min	Launch readiness §1

#	Topic	Duration	Source
6	Sprint plan — 4 sprints, 8 weeks, exit criteria per sprint	3 min	Launch readiness §3
7	Phased rollout — internal → beta → GA, rollback triggers	2 min	Launch readiness §5-6
8	Monitoring plan — dashboards, alarms, composite health	2 min	Launch readiness §8
9	Open questions — vendor API access, knowledge graph integration, privacy legal	4 min	PRD §6, Launch readiness §14
10	Next steps — S1 kickoff date, ownership, key decisions needed this week	2 min	Sprint breakdown, RACI
	Total	**30 min**	

13. Consolidated Risk Register

Source	Risk	L	I	Mitigation	Owner
PRD	Employee "spying" perception kills adoption	M	Critical	Transparency page, opt-in, team-level aggregation, employee FAQ, legal review	PM + Legal
PRD	Desktop AI detection accuracy < 80% in first 30 days	L	High	Curated allowlist (high precision); manual "add tool" fallback; expand in v2	Engineering
PRD	M365 Admin API access denied or delayed by Microsoft	M	Medium	Ship v1 without Copilot cost data; desktop detection still catches Copilot usage	Partnerships
PRD	Governance nudge UX annoys users, > 50% override rate	M	Medium	Frequency caps, tunability, A/B test nudge formats in beta	Design
PRD	Privacy regulations restrict desktop AI detection in EU	M	High	Legal review before EU launch; EU-specific detection scope	Legal
Gandalf	Customer evidence is market-level, not QD-specific	M	Medium	UXR interviews (8-10 customers) by Week 4 before design lock	UXR

Source	Risk	L	I	Mitigation	Owner
Gandalf	M365 Admin API dependency weakens cross-vendor cost value prop	M	Medium	Parallel-track Microsoft partnership + fallback cost estimation	PM + Partnerships
Gandalf	Legal/privacy review is critical path (6-8 week cycle)	H	High	Start legal engagement immediately in Week 1, not after design	PM + Legal
Design	Deep-link URL state adds frontend complexity	L	Low	Standard routing framework; well-understood pattern	Engineering
Design	Saved views require user preferences API extension	L	Medium	Validate QD preferences infrastructure in S1	QD Enterprise Team
Technical	Vendor API rate limits constrain cost data freshness	M	Medium	Daily batch refresh (not real-time), caching, graceful degradation	Engineering
Technical	QD knowledge graph may not expose AI tool signals today	M	High	Validate in Week 2 (Open Question #1); fallback to integration-only discovery	QD Core + Engineering
Security	Cross-vendor OAuth token storage is an attack surface	L	High	AWS Secrets Manager, rotation policy, audit logging	Security Engineering

14. Open Questions for Engineering

#	Question	Source	Owner	Due By
1	Does QD's knowledge graph currently capture AI tool interaction signals? Can we read them without performance impact?	PRD Open Question #1	QD Core Engineering	Week 2
2	What M365 Admin API data is available for Copilot usage and cost? What are the partnership terms?	PRD Open Question #2	Partnerships	Week 3

#	Question	Source	Owner	Due By
3	Can governance nudges be surfaced without impacting QD assistant latency (< 500ms)?	PRD Open Question #4	QD Performance Engineering	Week 3
4	What employee notification is legally required for desktop AI detection in US/EU/UK?	PRD Open Question #5	Legal	Week 4
5	Does QD have an existing user preferences storage API we can extend for saved views?	Design spec §3K (FTUX)	QD Enterprise Team	Week 1
6	What is the maximum Discovery Engine scan frequency that doesn't degrade QD core desktop performance?	Engineering feasibility	QD Performance Engineering	Week 2
7	Should governance_events use a separate DynamoDB table for append-only immutability vs. RDS?	Architecture decision	AI CT Engineering Lead	Week 1

Appendix: Artifact Links

Artifact	Version	Location
Research	v1	`research-v1.md` / `research-v1.pdf`
PRD	v3 (final)	`prd-v3.md` / `prd-v3.pdf`
Gandalf Evaluation	v1 (12/12 passed)	`gandalf-evaluation-v1.md` / `gandalf-evaluation-v1.pdf`
Design Spec	v1	`design-spec-v1.md` / `design-spec-v1.pdf`
Prototype	v1 (85% fidelity)	`prototype-v1.html`
Fidelity Report	v1	`fidelity-report-v1.md` / `fidelity-report-v1.pdf`
Current State Audit	v1	`current-state-v1.md` / `current-state-v1.pdf`